

How to answer the 10 security questions on a cyber-insurance application (honestly)

What each question really means, what a true "yes" takes, and the simplest way to get there.

Read this first. If a "yes" on your signed application is not true, the insurer may be able to deny a claim or rescind the policy (cancel it as if it never existed). A "no" with a plan is safer than a wrong "yes". Questions differ by insurer. Your agent or broker, not this sheet or your IT provider, decides with you how each one should be answered. Ask before you sign. Get proof from IT behind every "yes".

1. MFA on email. *Asks:* can a stolen password alone open a mailbox? *Honest yes:* every mailbox, the owner's included, needs a second sign-in step. *Gap:* a few exceptions. *Fix:* enforce MFA for everyone in your email settings.

2. MFA for remote access and admin accounts. *Asks:* is every outside way in protected? *Honest yes:* MFA on VPN, remote-desktop tools, cloud admin logins and the backup console. *Gap:* MFA on email only. *Fix:* list every remote tool and admin login; add MFA or remove it.

3. Backups. *Asks:* could you recover if ransomware locked everything tonight? *Honest yes:* automatic backups, one copy offline or unchangeable ("immutable"), and a restore you have tested. *Gap:* a plugged-in USB drive; file sync (OneDrive, Dropbox) counted as backup. *Fix:* a backup service with an immutable copy; schedule restore tests.

4. Endpoint protection (EDR). *Asks:* would anyone notice an attack? *Honest yes:* the tool the firm names (often EDR, not just antivirus) on every computer and server, with alerts watched. *Gap:* basic antivirus on some machines. *Fix:* one managed EDR product everywhere.

5. Patching. *Asks:* how fast are security updates installed? *Honest yes:* automatic updates on every computer, the firewall and anything facing the internet, with a report. *Gap:* out-of-support systems; a firewall nobody updates. *Fix:* automate updates; replace what no longer gets them.

6. Email filtering. *Asks:* are bad links and attachments screened out? *Honest yes:* link and attachment scanning is on; outside mail is tagged. *Gap:* default settings nobody reviewed. *Fix:* turn on your provider's scanning; set up SPF, DKIM and DMARC.

7. Security awareness training. *Asks:* how often are staff trained and tested? *Honest yes:* regular training, practice phishing emails, and a record of who finished. *Gap:* one talk, years ago. *Fix:* a training service that keeps records.

8. Privileged access. *Asks:* who can install software or change settings? *Honest yes:* staff use standard accounts; admin accounts are separate, few, and use MFA. *Gap:* everyone is an administrator. *Fix:* remove admin rights; keep a short list of admins.

9. Incident response plan. *Asks:* who does what in the first hour? *Honest yes:* a printed page saying who to call (insurer's claim line, IT, agent, attorney) and who decides. *Gap:* nothing written. *Fix:* write one page; review it yearly.

10. Vendor and wire-transfer verification. *Asks:* can one email change where money goes? *Honest yes:* a written rule to confirm every new or changed bank detail by calling a number you already had. *Gap:* done "usually". *Fix:* write the rule; two people approve large payments.

Questions? Supreme IT Experts - (610) 500-9209 - supremeitexperts.com - Free 30-minute IT + AI Checkup: supremeitexperts.com/checkup

General information, not legal, insurance or compliance advice.